

PACOTE DE DECISÃO E ARQUITETURA

Gate 0 — Fundação

API Management Tax

Campo	Definição
Documento	AMT-G0-DEC-001
Versão	0.1 — proposta para aprovação condicionada
Data	14 de agosto de 2026
Produto	Ferramenta interna corporativa
Fase autorizável	Desenvolvimento local do MVP 0 com dados exclusivamente sintéticos
Classificação	CONFIDENCIAL — uso interno

DECISÃO CENTRAL O API Management Tax será tratado no primeiro ciclo como ferramenta interna corporativa. A arquitetura preservará isolamento por tenant e capacidade de evolução, sem assumir obrigações comerciais de uma oferta SaaS.

LIMITE DE AUTORIZAÇÃO Este pacote não produz efeito autorizativo até a assinatura das concordâncias obrigatórias e a ratificação final do CFO. Mesmo após assinado, não autoriza produção, dados tributários reais, pareceres privilegiados, integrações corporativas nem acesso externo.

Minuta para CFO, Management Tax, Jurídico, Segurança, TI e Auditoria

0. Controle do documento

Elemento	Definição
Proprietário	Management Tax
Sponsor	CFO Regional
Aprovadores mínimos	Concordâncias de Management Tax, Jurídico, Segurança, TI/Plataforma e Auditoria; ratificação final do CFO
Propósito	Registrar decisões de fundação, limites de autorização, arquitetura de referência e evidências para iniciar o MVP 0.
Relação documental	Complementa API_Management_Tax_Especificacao_Consolidada.docx, v0.1 de 14/08/2026, e API_Management_Tax_Seguranca_Governanca_Auditabilidade.docx, v0.1 de 14/08/2026.
Regra de conflito	Prevalecem lei, obrigação contratual, política corporativa e decisão formal do aprovador competente.

0.1 Estado da decisão

Resultado	Alcance	Condição
PROPOSTA — NÃO EFETIVA	Desenvolvimento local e testes do MVP 0	Somente após concordâncias obrigatórias e ratificação do CFO; dados sintéticos; sem produção
BLOQUEADO	Dados reais e piloto operacional	Somente após Gate 2, revisão de privilege e autorização dos responsáveis
BLOQUEADO	Uso produtivo	Somente após Gate 7 e aceite formal do risco residual

0.2 Como usar este pacote

- Até que o registro de aprovação esteja completo, este documento é proposta de decisão e não autoriza iniciar desenvolvimento.
- Os aprovadores devem aceitar, rejeitar ou alterar cada ADR e cada pendência aberta.
- Uma decisão ainda não aprovada permanece proposta; silêncio ou início de desenvolvimento não equivalem a aprovação.
- Toda alteração posterior deve atualizar versão, responsável, data, justificativa e impacto nos gates.
- Evidências devem ser armazenadas no repositório governado, vinculadas ao requisito correspondente.

1. Síntese executiva

O Gate 0 estabelece as condições mínimas para que o API Management Tax avance de documentação para desenvolvimento controlado. O produto será uma ferramenta interna corporativa destinada a organizar jurisdições,

escritórios, decisões, riscos e evidências, sem substituir profissionais habilitados nem emitir conclusão jurídica autônoma.

A aprovação proposta é deliberadamente limitada ao MVP 0 em ambiente local ou de desenvolvimento isolado. O conjunto inicial inclui identidade federada, perfis, jurisdições, tiers, escritórios, classificação da informação, contexto de tenant e auditoria. Todo dado deve ser fictício ou sintético.

Três escolhas produtivas permanecem pendentes: provedor e configuração final de identidade, hospedagem/cofre de segredos e parâmetros definitivos de recuperação e retenção. O desenvolvimento pode avançar com contratos de integração e adaptadores, mas nenhuma dessas pendências pode ser resolvida informalmente no código.

VEREDITO O Gate 0 está documentalmente preparado para aprovação condicionada, mas permanece não efetivo. São necessárias as concordâncias de Management Tax, Jurídico, Segurança, TI/Plataforma e Auditoria, seguidas da ratificação final do CFO.

1.1 Objetivos mensuráveis do Gate 0

- Eliminar ambiguidade sobre o modelo de produto e os limites do primeiro ciclo.
- Definir uma arquitetura testável sem escolher prematuramente fornecedores produtivos.
- Tornar identidade, autorização, isolamento e auditoria requisitos de fundação, não incrementos posteriores.
- Registrar bloqueios claros para dados reais, privilege, integrações e produção.
- Produzir evidências suficientes para iniciar histórias do MVP 0 e a especificação OpenAPI.

2. Escopo e premissas aprováveis

2.1 Dentro do MVP 0

- Login federado por contrato OIDC ou SAML com o provedor corporativo existente; MFA aplicado pelo provedor.
- Perfis e atribuições de acesso com menor privilégio, segregação de funções e negação por padrão.
- Cadastro versionado de jurisdições, presença operacional, tiers e justificativas.
- Cadastro de escritórios, cobertura por jurisdição, contatos e status de validação.
- Classificação de informação explícita e herdável.
- Contexto obrigatório de tenant e políticas PostgreSQL RLS para dados segregados.
- Trilha de auditoria append-only para autenticação, acesso, alteração, exportação e administração.
- Ambiente local reproduzível com Docker, PostgreSQL, Prisma ORM/Migrate e massa sintética.

2.2 Fora da autorização deste Gate 0

- Dados tributários reais, documentos de clientes, credenciais produtivas ou cópias de bancos corporativos.
- Parecer jurídico integral ou material potencialmente privilegiado.
- Integrações reais com ERP, identidade, contratos, litígios, e-mail ou armazenamento corporativo.
- Uso externo, oferta SaaS, acesso de clientes ou escritórios por contas produtivas.
- Recomendação tributária automática, declaração de vigência legal ou aprovação autônoma por IA.
- Deploy produtivo, operação contínua ou compromisso de SLA externo.

2.3 Premissas operacionais

Premissa	Tratamento
Produto interno	Confirmada pelo responsável do projeto em 14/08/2026; requer registro formal do Sponsor.
Identidade	Reutilizar o IdP corporativo; fornecedor e atributos finais serão mapeados no ADR-002.
Tenancy	Um grupo corporativo no piloto, mas tenant_id obrigatório para segregação e evolução.
Dados	Somente sintéticos até Gate 2; dados reais exigem aprovação de Segurança, Jurídico e Produto.
Privilege	Parecer integral permanece fora; o MVP armazena apenas metadados/referência quando autorizado.
Hospedagem	Baseline neutro em fornecedor; produção bloqueada até ADR específico.

2.4 Taxonomia de classificação

Classe	Ordem	Uso permitido no MVP 0	Exportação
PÚBLICO	1 — menos restritiva	Somente representações sintéticas de fontes públicas; nenhuma cópia ou dado real	Permitida conforme contrato e auditoria
INTERNO	2	Metadados operacionais sintéticos	Somente usuário interno autorizado
CONFIDENCIAL	3	Estrutura e cenários sintéticos que revelem processo interno	Permissão específica, marca, finalidade e prazo
RESTRITO	4 — mais restritiva	Segredos, credenciais e chaves ficam fora do domínio	Bloqueada

- A classe mais restritiva prevalece; herança ocorre do objeto pai para anexos, exports e eventos derivados.
- Rebaixamento de classe exige Jurídico ou Segurança conforme a natureza, justificativa, aprovador, data e AuditEvent.
- Acesso exige simultaneamente papel, tenant, jurisdição quando aplicável, classe e finalidade compatíveis.

2.5 Metadados de parecer e privilege

Privilege é um atributo jurídico ortogonal à classificação da informação, nunca um degrau da escala PÚBLICO–RESTRITO. O campo legal_privilege admite NONE, POTENTIAL, CONFIRMED ou WAIVED. POTENTIAL e CONFIRMED aplicam controles adicionais independentemente da classe; WAIVED somente pode ser definido pelo Jurídico com decisão e evidência próprias.

Permitido somente após autorização do Jurídico	Proibido no MVP 0
reference_id opaco; jurisdição; escritório; data do parecer; categoria de assunto; status de validação; classe; owner; identificador da aprovação jurídica; política de retenção; URI opaca do repositório autorizado	Arquivo ou texto integral; conclusão; tese; recomendação; citação substantiva; resumo livre; e-mail; anexo; OCR; embedding; prompt; conteúdo extraído ou dado que revele a orientação jurídica

- Inclusão de referência exige aprovação conjunta de Jurídico e Management Tax e permanece bloqueada até o Gate 2.
- O repositório externo, o efeito sobre privilege e a retenção devem ser aprovados por jurisdição antes de qualquer referência real.

3. Arquitetura de referência

A arquitetura separa identidade, autorização, domínio, persistência e evidência. Cada camada deve negar acesso quando o contexto necessário estiver ausente e emitir eventos correlacionáveis para operações sensíveis.

Camada	Responsabilidade	Controle obrigatório
Usuário e estação	Acesso por navegador ou cliente aprovado	Estação autorizada; sessão curta; nenhuma credencial compartilhada
Identidade corporativa	Autenticação, MFA e lifecycle	Federação; grupos/claims mínimos; revogação e trilha do IdP
API / gateway	TLS, validação de token, rate limit e correlation_id	Negação por padrão; erros sem vazamento; limites por identidade
Autorização	RBAC para função e ABAC para tenant, jurisdição, classificação e contexto	Teste positivo e negativo; decisão auditável
Serviços de domínio	Jurisdictions, offices, identity administration e audit query	Validação; idempotência; regras versionadas
Persistência	PostgreSQL e Prisma Migrate	tenant_id; RLS forçada; usuário da aplicação sem BYPASSRLS
Auditoria	Eventos append-only e evidência de integridade	UTC; actor; resource; before/after seguro; hash e correlation_id
Plataforma	Containers, pipeline, segredos, backup e observabilidade	Não root; imagem mínima; cofre; scans; artefato imutável

3.1 Fluxo de confiança

1. O usuário autentica no provedor corporativo e recebe token de curta duração.
2. A API valida emissor, audiência, expiração, MFA/assurance e identificador da sessão.
3. O middleware resolve tenant, função, jurisdição e classificação; contexto incompleto é negado.
4. O serviço aplica autorização contextual e validação de domínio antes de consultar ou alterar dados.
5. A sessão do banco recebe contexto controlado; RLS filtra linhas independentemente da consulta ORM.
6. A operação e seu resultado geram AuditEvent com correlation_id e referência segura de antes/depois.
7. Métricas e alertas detectam negações anormais, exportações, falhas de integridade e comportamento suspeito.

3.2 Fronteiras de confiança

Fronteira	Risco	Regra de passagem
Usuário → identidade	Conta comprometida	MFA; lifecycle; detecção de risco; sem conta compartilhada
Identidade → API	Token forjado, expirado ou para outro público	Validação criptográfica completa e claims mínimos

Fronteira	Risco	Regra de passagem
API → domínio	Escalada por endpoint	Autorização central e contextual antes de qualquer ação
Domínio → banco	Acesso cruzado entre tenants	RLS forçada e contexto definido pela aplicação confiável
Sistema → exportação	Exfiltração	Permissão específica, propósito, classificação, marca e auditoria
Pipeline → produção	Artefato ou segredo indevido	Aprovação, scans, digest, cofre e ambiente protegido

4. Registros de decisão arquitetural — ADRs

ADR-001 — Modelo de produto

Campo	Registro
Decisão	Ferramenta interna corporativa no primeiro ciclo.
Estado	PROPOSTO — não efetivo até concordâncias obrigatórias e ratificação do Sponsor.
Racional	Atende à governança regional sem introduzir contratos, billing, suporte externo ou tenancy comercial.
Consequência	Não haverá acesso de clientes ou escritórios produtivos no MVP 0; evolução futura exige novo ADR e revisão de risco.
Aprovador/vigência	CFO/Sponsor; vigente somente após registro de assinatura e data.

ADR-002 — Identidade federada e MFA

Campo	Registro
Decisão	Usar o provedor corporativo existente por OIDC preferencialmente, ou SAML quando obrigatório; proibir senha local para contas humanas.
Estado	PROPOSTO — não efetivo; provedor, claims, grupos e lifecycle pendentes de TI/Segurança.
Racional	Centraliza MFA, revogação, joiner/mover/leaver e evidências de autenticação.
Consequência	O desenvolvimento usa um adaptador de identidade e um emissor local sintético; integração real permanece bloqueada.
Aprovador/vigência	Segurança e TI concordam; CFO ratifica; vigente somente após assinatura e data.

ADR-003 — Isolamento por tenant e PostgreSQL RLS

Campo	Registro
Decisão	Todo dado segregável terá tenant_id não nulo; RLS será forçada no PostgreSQL e complementada por autorização contextual.
Estado	PROPOSTO — requisito não dispensável após ratificação.
Racional	Evita que erro de consulta, ORM ou endpoint exponha registros de outro escopo.
Consequência	Migrações, índices, chaves únicas, testes e auditoria devem incluir tenant; BYPASSRLS é proibido para a aplicação.
Aprovador/vigência	Segurança concorda; TI/Engenharia responde pela implementação; CFO ratifica.

ADR-004 — Auditoria como domínio independente

Campo	Registro
Decisão	Eventos sensíveis serão append-only, correlacionáveis e protegidos por evidência de integridade.
Estado	PROPOSTO — requisito não dispensável após ratificação.
Racional	Logs operacionais não comprovam decisão, autorização, alteração nem cadeia de reliance.
Consequência	Correções geram novos eventos; acesso e exportação da trilha também são auditados; segredos nunca entram no payload.
Aprovador/vigência	Auditoria e Segurança concordam; CFO ratifica; vigente somente após assinatura e data.

ADR-005 — Baseline portátil de plataforma e segredos

Campo	Registro
Decisão	Desenvolvimento em containers não root, configuração externa e interface de cofre; fornecedor produtivo não será codificado no domínio.
Estado	PROPOSTO — baseline de desenvolvimento pendente de ratificação; hospedagem e cofre produtivos pendentes.
Racional	Permite avançar sem transformar uma escolha não aprovada em dependência estrutural.
Consequência	Deploy produtivo é bloqueado até ADR de hospedagem, regiões, custos, chaves e responsabilidades operacionais.
Aprovador/vigência	Segurança e TI/Plataforma concordam; CFO ratifica; vigência limitada ao desenvolvimento.

ADR-006 — Dados sintéticos e privilege

Campo	Registro
Decisão	Até o Gate 2, somente dados sintéticos. Parecer integral e material potencialmente privilegiado ficam fora do sistema.
Estado	PROPOSTO — requisito não dispensável após ratificação.
Racional	Reduz exposição regulatória e evita perda de privilege antes de parecer jurídico por jurisdição.
Consequência	Fixtures devem ser manifestamente fictícias; anexos reais, dumps, e-mails e credenciais são proibidos.
Aprovador/vigência	Jurídico, Segurança e Management Tax concordam; CFO ratifica; vigente somente após assinatura e data.

5. Modelo lógico do MVP 0

Entidade	Finalidade e campos mínimos	Controles
Tenant	tenant_id, nome interno, estado, criado_em	Raiz de segregação; alteração restrita
UserIdentity	user_id, subject_id, issuer, e-mail corporativo, estado, last_seen	Sem senha local; unique(issuer, subject_id); PII mínima
UserTenantMembership	tenant_id, user_id, estado, início/fim, requested_by, approved_by	FK composta; requester ≠ approver; sem tenant implícito
AccessRequest	tenant_id, user_id, role, jurisdictions, max_class, allowed_purposes, motivo, validade, requester, approvers, estado	Dupla aprovação quando privilegiado; expiração; AuditEvent
RoleAssignment	tenant_id, user_id, role, jurisdiction_id opcional, max_class, allowed_purposes, início/fim, approved_by	Derivada de AccessRequest; FK para membership; revogável
Jurisdiction	tenant_id, código, nome, presença, moeda, idioma, status	RLS; versão; owner
TierVersion	tenant_id, jurisdiction_id, tier, justificativa, vigente_de/até, aprovador	FK composta no mesmo tenant; histórico imutável
Office	tenant_id, firma, estado, classificação, contatos mínimos	RLS; minimização; classificação
OfficeCoverage	tenant_id, office_id, jurisdiction_id, escopo, início/fim, status	FKs compostas no mesmo tenant; conflito detectável
InformationClass	código PÚBLICO/INTERNO/CONFIDENCIAL/RESTRITO, regras de acesso, retenção e exportação	Política central versionada
PrivilegeMarker	resource_type/id, legal_privilege, jurisdiction_id, legal_approval_id, vigência	Ortogonal à classe; alteração exclusiva do Jurídico
PurposeCode	OPERATE_TAX, REVIEW_TAX, AUDIT, SECURITY_INVESTIGATION, PLATFORM_ADMIN, EXECUTIVE_REPORTING	Vocabulário fechado e versionado
AuditEvent	event_id, occurred_at_utc, actor, tenant, resource, action, result, correlation_id, prev_mac, integrity_mac, key_version	Append-only; writer dedicado; sem segredo
AccessReview	tenant_id, período, escopo, reviewer, achados, decisão, concluído_em	RLS; evidência de revisão periódica

5.1 Invariantes

- Entidade sujeita a segregação não pode existir sem tenant_id.

- Tier, cobertura e atribuição de acesso são temporais; alterações não apagam o histórico.
- A aplicação nunca aceita tenant_id fornecido pelo cliente como autoridade suficiente; o contexto deriva da identidade e da autorização.
- AuditEvent não pode ser atualizado nem excluído pelo usuário da aplicação.
- Toda operação administrativa exige motivo controlado, aprovador quando aplicável e correlation_id.
- Classificação mais restritiva prevalece quando objeto, anexo e contexto divergirem.

5.2 Semântica de tenant

- No piloto, Tenant representa uma unidade corporativa isolada; Tenant A e Tenant B são partições sintéticas usadas para provar isolamento.
- A identidade autenticada não recebe acesso por existir no IdP: ela precisa de UserTenantMembership ativo e RoleAssignment válido.
- Um usuário pode pertencer a mais de um tenant somente por memberships independentes e aprovados; não existe tenant global implícito.
- Um header ou parâmetro de tenant pode selecionar entre memberships válidos, mas nunca concede autoridade. A API resolve e valida o contexto no servidor.
- Acesso cruzado excepcional não existe no MVP 0; suporte futuro exigirá papel específico, dupla aprovação, prazo, finalidade e trilha separada.
- FKs e unicidades compostas incluem tenant_id para impedir OfficeCoverage, TierVersion ou RoleAssignment entre tenants.

5.3 Contrato PostgreSQL RLS e Prisma

Elemento	Decisão técnica mínima
Papéis	app_migrator altera schema e não atende requisições; app_runtime não possui BYPASSRLS; app_audit_writer insere eventos e não atualiza/exclui.
Políticas	ENABLE ROW LEVEL SECURITY e FORCE ROW LEVEL SECURITY em toda tabela segregada; USING e WITH CHECK validam tenant_id.
Contexto	Cada operação abre transação e aplica set_config('app.tenant_id', valor_validado, true); nenhum contexto persiste fora da transação.
Pooling	Checkout não confia em estado anterior; reset e teste de ausência de contexto são obrigatórios; falha de contexto nega acesso.
Prisma	Acesso segregado ocorre dentro de wrapper transacional único; query fora do wrapper falha; migração não usa app_runtime.
Teste	Tenant A/B por tabela, leitura por ID conhecido, INSERT/UPDATE cruzado, ausência de contexto, pooling reutilizado e regressão após migração.

5.4 Integridade da auditoria

- Um writer dedicado cria cada evento com prev_mac, integrity_mac autenticado e key_version; hash sem chave não é evidência suficiente contra agente com acesso ao banco.
- A chave vem do cofre, é separada do banco e rotacionável; o ambiente local usa chave sintética explicitamente não produtiva.

- Update e delete são negados ao writer e ao runtime; correção produz evento compensatório vinculado ao original.
- Um verificador independente recalcula a cadeia e registra resultado; produção exige ancoragem periódica do digest em destino externo imutável ou serviço corporativo de segurança.
- Leitura, verificação e exportação da trilha são funções distintas e também geram eventos.

6. Modelo de acesso

Legenda: A = administrar; E = editar; L = ler; X = exportar controladamente; — = sem acesso. Toda permissão continua sujeita a tenant, jurisdição, classificação, finalidade e estado do registro.

Perfil	Jurisd./tiers	Escritórios	Usuários/acessos	Auditoria	Configuração
Management Tax	E	E	L	L	L
Tax Reviewer	L	L	—	L	—
Platform Admin	—	—	A	L	A
Security Admin	L	L	A	L/X	A
Auditor	L	L	L	L/X	L
Executive Reader	L	L	—	—	—

6.1 Políticas executáveis mínimas

Subject	Action	Resource	Condições cumulativas	Resposta de negação
Management Tax	read/write	Jurisdiction, TierVersion, Office, OfficeCoverage	membership ativo; mesmo tenant; jurisdição no escopo quando restrita; classe ≤ autorização	403 para ação; 404 para ID fora do tenant
Management Tax	read	RoleAssignment	mesmo tenant; sem segredo técnico; finalidade administrativa	403
Tax Reviewer	read	Jurisdiction, Office	mesmo tenant; jurisdição atribuída; max_class ≥ classe; purpose REVIEW_TAX	404 para ID fora do escopo
Tax Reviewer	read	AuditEvent	somente eventos do próprio fluxo; sem before/after restrito	403
Platform Admin	admin	Configuração técnica e identidade técnica	janela/justificativa; sem conteúdo fiscal; concessão privilegiada válida	403 e alerta
Security Admin	read/export	AuditEvent e metadados	purpose SECURITY_INVESTIGATION; export aprovado; legal_privilege NONE por padrão	403 e alerta
Auditor	read/export	Registros e AuditEvent	escopo e período aprovados; finalidade de auditoria; export marcado e temporário	403

Subject	Action	Resource	Condições cumulativas	Resposta de negação
Executive Reader	read	Visões consolidadas	mesmo tenant; purpose EXECUTIVE_REPORTING; classe diferente de RESTRITO; legal_privilege NONE	403

Sem identidade válida: 401. Recurso identificado por ID que pertença a outro tenant ou jurisdição invisível: 404. Identidade válida no escopo, mas sem permissão para a ação: 403. A OpenAPI deve aplicar essa regra uniformemente.

6.2 Ciclo de concessão, revogação e revisão

Etapa	Responsável	Regra executável
Solicitar	Management Tax ou gestor autorizado	Criar AccessRequest com tenant, papel, jurisdições, max_class, allowed_purposes, motivo e expiração; não cria acesso.
Aprovar acesso de negócio	Owner Management Tax	Approver diferente do requester; confirma necessidade, jurisdição, classe e finalidade.
Aprovar papel privilegiado	Security Admin + owner de negócio	Dupla aprovação obrigatória para Platform Admin, Security Admin, exportação ou classe RESTRITO.
Conceder	Serviço de identidade	Somente AccessRequest APPROVED gera Membership/RoleAssignment; serviço não pode autoaprovar.
Revogar	Owner, Security Admin ou lifecycle do IdP	Revogação imediata, motivo, actor e AuditEvent; sessões e cache de autorização são invalidados.
Revisar	Owner + Segurança	Revisão trimestral e por mudança de função; acesso expirado ou sem owner é removido, nunca renovado silenciosamente.

A autorização avalia role, membership, jurisdiction_id, max_class e purpose_code. A finalidade é escolhida em vocabulário fechado, deve estar em allowed_purposes do RoleAssignment e é registrada no AuditEvent; texto livre não concede finalidade.

6.3 Regras transversais

- Negação por padrão; nenhuma função implica acesso global por conveniência.
- Platform Admin mantém infraestrutura, mas não recebe automaticamente conteúdo tributário.
- Security Admin pode investigar eventos e metadados sem obter parecer privilegiado por padrão.
- Auditor possui leitura controlada; exportação exige propósito, prazo, marca, autorização e evento de auditoria.
- Atribuição privilegiada é temporária, justificada, revisada e incompatível com autoaprovação.
- Acesso de escritório externo permanece fora do MVP 0 produtivo.

6.4 Testes mínimos de autorização

Cenário	Resultado esperado	Evidência
Sem identidade	401 e nenhum dado	Teste de contrato e evento de negação
Identidade sem papel	403 e nenhum dado	Teste automatizado
Tenant A tenta ler Tenant B	Nenhuma linha, inclusive por ID conhecido	Teste API + banco/RLS
Jurisdição fora do escopo consultada por ID	404 e nenhum dado	Teste de política e anti-enumeração
Platform Admin tenta conteúdo fiscal	Negado sem concessão separada	Teste de segregação
Exportação sem permissão	Negada e auditada	Teste funcional e AuditEvent

7. Threat model inicial

ID	Ameaça	Controle preventivo/detectivo	Residual	Gate
T-01	Acesso cruzado entre tenants	Contexto confiável; RLS forçada; chaves compostas; testes A/B; alerta de negação anormal	Médio	2
T-02	Escalada de privilégio	RBAC+ABAC; segregação; concessão temporária; revisão; trilha	Médio	1–2
T-03	Adulteração da auditoria	Writer dedicado; MAC encadeado; chave externa; verificador; ancoragem externa em produção	Médio	2
T-04	Segredo em Git, imagem ou log	Cofre; scanners; rotação; redaction; imagem mínima	Médio	3
T-05	Token roubado ou IdP comprometido	MFA; sessão curta; validação completa; revogação; detecção	Médio/alto	1
T-06	Exportação ou consulta em massa	Permissão específica; limites; marca; purpose binding; alertas	Médio	2
T-07	Perda de privilege	Parecer integral fora; classificação; referência externa; aprovação jurídica	Alto até parecer	0/2
T-08	Migração destrutiva	Prisma Migrate; PR; banco descartável; expand-contract; forward-fix	Médio	3
T-09	Dependência comprometida	Lockfile; SCA; SBOM; assinatura/digest; atualização governada	Médio	3/7
T-10	Uso de dado real em desenvolvimento	Fixtures sintéticas; bloqueio de pipeline; revisão de dataset; DLP quando disponível	Baixo/médio	2

7.1 Casos de abuso prioritários

1. Usuário altera tenant_id ou jurisdiction_id na requisição para acessar objeto conhecido.
2. Administrador técnico consulta dados fiscais sem função de negócio.
3. Usuário autorizado exporta volume incompatível com sua finalidade.
4. Atacante reutiliza token expirado, de outro audience ou sessão revogada.
5. Desenvolvedor conecta Prisma Studio a banco não sintético.
6. Migração remove política RLS ou coluna de tenant sem detectar regressão.
7. Correção de evento apaga evidência em vez de produzir evento compensatório.
8. Documento privilegiado é anexado a registro classificado incorretamente.

7.2 Método, ownership e aceite residual

- Severidade combina impacto e probabilidade em quatro níveis: Baixo, Médio, Alto e Crítico; o racional deve acompanhar cada mudança de nível.
- Segurança mantém o registro e define prazo técnico; o owner de negócio responde pelo tratamento no domínio afetado.
- Risco Alto ou Crítico não pode ser aceite apenas por Engenharia. Exige Segurança, owner de negócio e CFO; privilege exige também Jurídico.
- Aceite residual possui justificativa, controles compensatórios, data de expiração e revisão no gate seguinte.

7.3 Política executável de dados sintéticos

- Fixtures ficam em diretório identificado, com manifest contendo owner, finalidade, gerador, data e declaração de não derivação de dado real.
- Toda alteração de fixture exige revisão por segundo autor e teste automatizado de padrões de segredo, identificadores e PII.
- O pipeline bloqueia arquivos fora do manifest, dumps, formatos não autorizados, chaves e padrões proibidos; falso positivo requer exceção registrada e temporária.
- Valores canário e nomes obviamente fictícios permitem reconhecer a massa; cópia, anonimização ad hoc ou transformação de produção não são aceitas como dado sintético.

8. RACI do Gate 0

R = executa; A = accountable/ratifica; C = consultado; I = informado; C* = concordância formal obrigatória; R* = responsável cuja concordância também é obrigatória.

Atividade	Mgmt Tax	CFO	Jurídico	Segurança	TI/Eng.	Auditoria
Modelo de produto	R	A	C	C	I	I
Lista de jurisdições e tiers	R	A	C	I	I	I
Materialidade e apetite	C	A	C	C	I	I
Classificação e privilege	C	I	A/R	C	I	I
Identidade e MFA	C	I	I	A	R	I
Autorização e RLS	C	I	C	A	R	C
Auditoria e evidências	C	I	C	C	R	A
Hospedagem e cofre	C	I	C	A	R	I
RPO/RTO e retenção	C	A	C	C	R	I
Aceite do Gate 0	R*	A	C*	C*	C*	C*

Para o aceite do Gate 0, CFO é o ratificador final (A), mas só pode ratificar após concordâncias formais e registradas de Management Tax, Jurídico, Segurança, TI/Plataforma e Auditoria. A concordância da Auditoria sobre o desenho de evidências é condição bloqueadora de eficácia e deve constar no registro de aprovação.

8.1 Segregações mínimas

- Quem solicita acesso não aprova a própria concessão privilegiada.
- Quem desenvolve não aprova sozinho o release nem a migração produtiva.
- Quem administra infraestrutura não recebe acesso automático ao conteúdo de negócio.
- Quem publica regra tributária não pode alterar silenciosamente sua evidência histórica.
- Quem investiga incidente preserva evidência e registra toda ação excepcional.

9. Recuperação, retenção e descarte

PROPOSTA PROVISÓRIA Os valores abaixo servem apenas para desenvolvimento sintético e planejamento. Parâmetros produtivos dependem de CFO, Jurídico, Segurança e Operações.

Classe/ambiente	RPO proposto	RTO proposto	Retenção	Estado
Desenvolvimento sintético	24 horas	1 dia útil	30–90 dias; recriável	Pode avançar
Código e migrações	Por commit	4 horas	Histórico do repositório	Pode avançar
Auditoria de teste	24 horas	1 dia útil	90 dias	Pode avançar
Produção	A definir	A definir	Por classe/jurisdição/legal hold	Bloqueado
Parecer privilegiado	Fora do MVP	Não aplicável	Definida pelo Jurídico	Bloqueado

9.1 Regras

- Retenção é definida por classe e jurisdição; prazo global não pode reduzir obrigação mais restritiva.
- Legal hold suspende descarte sem alterar a evidência de que o prazo normal expirou.
- Backups obedecem à mesma classificação dos dados de origem e não podem abastecer desenvolvimento.
- Descarte deve ser verificável, auditado e propagado para réplicas, exports e mídias conforme capacidade técnica.
- Teste de restauração deve validar schema, RLS, auditoria, chaves, regras e consistência funcional.

10. Evidências e critérios de saída

10.1 Matriz de rastreabilidade

Fontes: EC-0.1 = Especificação Consolidada v0.1; SG-0.1 = Especificação de Segurança, Governança e Auditabilidade v0.1, ambas de 14/08/2026.

Fonte/requisito	Decisão	Evidência	Gate
EC-0.1 §12–13 — modelo interno e fundação	ADR-001	G0-E01	0
SG-0.1 §4 e SEC-IAM-001/002 — identidade	ADR-002	G0-E06 + ciclo 6.2 + testes 6.4	1
SG-0.1 §5 e SEC-DAT-001 — tenant/RLS	ADR-003	Contrato 5.2/5.3 + testes A/B	2
SG-0.1 §6 e SEC-AUD-001/002 — auditoria	ADR-004	Contrato 5.4 + verificação	2
SG-0.1 §7–8 e SEC-PLT-002 — plataforma/segredos	ADR-005	G0-E07 + pipeline	3
EC-0.1 §10 e SG-0.1 §3 — classificação/privilege	ADR-006	Taxonomia 2.4/2.5 + G0-E05	0/2
SG-0.1 §13 e D-002 — recuperação/retenção	ADR futuro de produção	G0-E08	0/5

10.2 Quadro de evidências

ID	Evidência	Critério de aceite	Owner	Estado
G0-E01	Modelo de produto	ADR-001 ratificado pelo Sponsor	CFO/Mgmt Tax	Pendente assinatura
G0-E02	Arquitetura de referência	Camadas, fronteiras e fluxos revisados	Eng./Segurança	Proposta pronta
G0-E03	Threat model	Ameaças, controles, residual e gates revisados	Segurança	Proposta pronta
G0-E04	RACI	Owners e segregações aceitos	CFO	Proposta pronta
G0-E05	Classificação/privilege	Classes e regra de parecer aprovadas	Jurídico	Pendente
G0-E06	Identidade	IdP, protocolo, claims, lifecycle e MFA definidos	TI/Segurança	Pendente

ID	Evidência	Critério de aceite	Owner	Estado
G0-E07	Hospedagem/cofre	Região, serviço, chaves, custo e owners definidos	TI/Segurança	Pendente
G0-E08	RPO/RTO/retenção	Valores produtivos aprovados por classe	CFO/Jurídico/Ops	Pendente
G0-E09	Política de dados sintéticos	Fixtures e bloqueios documentados	Produto/Segurança	Proposta pronta

10.3 Definition of Ready para o MVP 0

- ADRs versionados e sem conflito com as especificações anteriores.
- Histórias possuem critérios de autorização positiva e negativa.
- Modelo lógico identifica tenant, classificação, owner e histórico.
- Contratos de AuditEvent e erros estão definidos na OpenAPI.
- Massa sintética identificável e sem derivação de dado real.
- Ambiente local reproduzível e sem credencial produtiva.
- Pendências produtivas permanecem bloqueadas por configuração e pipeline, não apenas por instrução textual.

11. Decisões abertas e bloqueios

ID	Decisão necessária	Responsável	Prazo	Efeito se pendente
D-01	Lista real de jurisdições com operação	CFO/Operações	Antes do cadastro real	Usar somente fixtures
D-02	Materialidade numérica	CFO/Board	Antes de gates de negócio	Sem automação de alçada
D-03	Apetite de risco	CFO/Board	Antes de exceções	Negação conservadora
D-04	Classes autorizadas em IA/terceiros	Jurídico/Segurança	Antes do módulo de conhecimento	Integração bloqueada
D-05	Destino de parecer privilegiado	Jurídico	Antes de anexos/referências reais	Parecer fora do sistema
D-06	Sistemas fonte e contratos de integração	TI/Controladoria	Antes de integração	Mocks/adaptadores
D-07	RPO, RTO, retenção e regiões	CFO/Jurídico/Segurança/Ops	Antes de produção	Produção bloqueada
D-08	Owner de cada dado e indicador	Management Tax	Antes de carga real	Sem carga real
D-09	Primeiro scorecard não punitivo	CFO	Antes do MVP 2	Scorecard não publicado
D-10	Ratificar ferramenta interna corporativa	CFO/Sponsor	Antes de iniciar o MVP 0	Pacote não efetivo
D-11	IdP, claims, grupos e lifecycle	TI/Segurança	Antes do Gate 1	Emissor sintético local
D-12	Hospedagem, região e cofre	TI/Segurança	Antes do Gate 3	Somente local

APÓS A RATIFICAÇÃO DO GATE 0 As pendências produtivas acima não impedem a criação da OpenAPI, do modelo Prisma inicial, de testes com tenants fictícios e do ambiente Docker local. Antes da ratificação, porém, este pacote não autoriza iniciar o scaffold.

12. Plano de execução após aprovação

12.1 Primeiros 10 dias úteis

1. Registrar este pacote e seus ADRs no repositório privado.
2. Criar OpenAPI 0.1 com health, identity context, jurisdictions, offices e audit-events.
3. Definir schema Prisma do MVP 0 e migração inicial sem dados reais.
4. Implementar contexto de tenant, autorização central e política RLS mínima.
5. Criar fixtures para Tenant A e Tenant B e testes adversariais de isolamento.
6. Definir schema mínimo de AuditEvent e eventos de autenticação, negação e alteração.
7. Configurar Docker local não root, healthcheck e PostgreSQL restrito a localhost.
8. Adicionar lint, testes, scan de segredo e verificação de migração ao pipeline local/CI.

12.2 Critérios para avançar ao Gate 1

- Contrato do IdP e claims aprovado, ainda que testado inicialmente por emissor sintético.
- Matriz de acesso transformada em políticas executáveis e casos de teste.
- Nenhuma rota de negócio funciona sem identidade e contexto válido.
- Atribuições privilegiadas possuem validade, motivo, aprovador e evento de auditoria.
- Documentação de setup não requer segredo produtivo nem dado real.

12.3 Próximo artefato

OPENAPI 0.1 O próximo artefato técnico deve transformar este pacote em contratos verificáveis, incluindo autenticação, autorização, paginação, idempotência, erros, correlation_id e schemas do MVP 0.

13. Registro de aprovação

A assinatura abaixo confirma apenas o alcance indicado. Alterações de escopo, dados ou ambiente exigem nova avaliação.

Papel	Nome	Decisão	Data	Condições/observações
CFO / Sponsor		Aprovar / rejeitar / alterar		
Management Tax		Aprovar / rejeitar / alterar		
Jurídico		Aprovar / rejeitar / alterar		
Segurança		Aprovar / rejeitar / alterar		
TI / Plataforma		Aprovar / rejeitar / alterar		
Auditoria		Aprovar evidências / alterar		

13.1 Declaração de aceite proposta

Os signatários autorizam a preparação do MVP 0 em ambiente local ou de desenvolvimento isolado, utilizando exclusivamente dados sintéticos, observadas as decisões, restrições e evidências deste pacote. Nenhum signatário autoriza, por este ato, dados reais, parecer privilegiado, integração produtiva, acesso externo ou operação em produção.

Apêndice A — Glossário

Termo	Definição
ABAC	Autorização baseada em atributos de identidade, dado e contexto.
ADR	Registro versionado de decisão arquitetural e suas consequências.
Gate	Portão formal com saída, evidência e aprovadores definidos.
IdP	Provedor corporativo de identidade.
MVP 0	Fundação: identidade, perfis, classificação, auditoria, jurisdições, tiers e escritórios.
RLS	Row-Level Security do PostgreSQL para restringir linhas pelo contexto confiável.
RPO/RTO	Perda de dados tolerada e tempo-alvo de recuperação.
Tenant	Unidade organizacional isolada logicamente no sistema.